

Lab advanced sql injection and RBAC

Lab 1: Implementing RBAC

Query	Query History
1	-- 1. Tạo nhóm Role
2	CREATE ROLE cashier_role;
3	
4	-- 2. Tạo User cho nhân viên
5	CREATE USER mike WITH PASSWORD 'mike123';
6	CREATE USER jon WITH PASSWORD 'jon123';
7	
8	-- 3. Gán User vào nhóm
9	GRANT cashier_role TO mike;
10	GRANT cashier_role TO jon;
11	
12	-- 4. Cấp quyền truy cập cho nhóm Cashier
13	GRANT SELECT ON film, staff TO cashier_role;
14	GRANT SELECT, INSERT ON payment TO cashier_role;

Data Output	Messages	Notifications
GRANT		
	Query returned successfully in 119 msec.	

Lab 2: Implementing RLS

Create policy RLS:

Query

Query History

```
1  -- 1. Bật tính năng RLS trên bảng payment
2  ALTER TABLE payment ENABLE ROW LEVEL SECURITY;
3
4  -- 2. Tạo Policy lọc dữ liệu
5  CREATE POLICY isolate_cashier_payments ON payment
6  FOR SELECT TO cashier_role
7  USING (
8      staff_id = (SELECT staff_id FROM staff WHERE username = current_user)
9  );
```

Data Output

Messages

Notifications

```
CREATE POLICY

Query returned successfully in 406 msec.
```

Check mike's insight

14

SET ROLE mike;

15

SELECT COUNT(*) FROM payment;

Data Output

Messages

Notifications

≡+

▼

▼

SQL

	count bigint
1	7292

Check jon's insight:

17
18

SET ROLE jon;

SELECT COUNT(*) FROM payment;

Data Output

Messages

Notifications

≡+

📄

▼

📋

▼

🗑

🗄

⬇

📈

SQL

	count bigint 🔒
1	7304